

SOC ANALYST PORTFOLIO CASE STUDY

Case 03 - Phishing Investigation and Account Compromise

Field	Value	Field	Value
Analyst	Akachi Maduako	Role	SOC Analyst L1
Environment	Synthetic lab / dummy data	Verdict	TRUE POSITIVE
Severity	HIGH	Primary user	j.smith
Affected host	WIN-LT-023	Case type	Phishing / account compromise

1. Executive Summary

A synthetic phishing campaign impersonating Microsoft Security was investigated using email, message-trace, DNS, proxy/web, identity sign-in, IOC-enrichment, and attachment evidence. The investigation found that the phishing message reached j.smith, the user's workstation resolved and visited the phishing infrastructure, and suspicious password-only sign-ins from Amsterdam subsequently succeeded. The evidence supports a high-confidence true-positive phishing incident resulting in likely account compromise.

Final disposition: Escalate to SOC L2 / Incident Response for containment and broader scoping.

2. Investigation Objective

Determine whether the suspicious email represented a genuine phishing attempt, whether a user interacted with it, whether credentials were likely compromised, and whether follow-on identity activity indicated successful account takeover.

3. Evidence Sources

- Suspicious email (.eml) and authentication headers.
- Message trace showing recipients, delivery status, sender, and originating IP.
- DNS events from the affected workstation.
- Proxy/web events showing requests to the suspicious domain.
- Identity sign-in records showing location, result, authentication detail, browser, and device.
- IOC enrichment records for domains and IP addresses.
- Attachment metadata plus independent SHA-256 verification.

4. Key Findings

Email impersonation: The sender used the lookalike domain micros0ft-support.example and a Microsoft Security theme.

Authentication failure: The message showed SPF failure and DMARC failure; DKIM was absent.

Campaign scope: Message-trace evidence showed delivery to j.smith, a.chen, and m.patel.

User interaction: WIN-LT-023 resolved secure-login.example and subsequently made web requests to the phishing infrastructure.

Credential compromise indicator: j.smith later authenticated from 198.51.100.91 in Amsterdam, NL. The sequence included an invalid-password failure followed by successful password-only authentication.

Baseline contrast: An earlier Toronto sign-in for j.smith showed MFA satisfied, making the later password-only Amsterdam activity materially suspicious.

Attachment validation: Password_Expiration_Instructions.txt was classified by the supplied lab metadata as a benign decoy / lab artifact; the independently calculated SHA-256 matched the supplied metadata.

5. Correlated Attack Timeline

Time (UTC)	Evidence	Observation
13:42:16	Message trace	Suspicious Microsoft-themed email delivered to j.smith from 203.0.113.77.
13:49:58	DNS	WIN-LT-023 resolves secure-login.example to 198.51.100.66.
13:50:11	Proxy/Web	j.smith visits /m365/verify?user=j.smith on secure-login.example.
13:50:59	DNS	WIN-LT-023 resolves cdn.secure-login.example to 198.51.100.67.
13:51:03	Proxy/Web	Browser requests /assets/loader.js from related phishing infrastructure.
13:54:27	Identity	Amsterdam sign-in from 198.51.100.91 fails with invalid password.
13:55:04	Identity	Same Amsterdam source successfully authenticates using password only.
13:56:22	Identity	Additional successful password-only authentication from the same source.

6. Indicators of Compromise

Type	Indicator	Risk / significance
Domain	secure-login.example	High - observed phishing URL
Domain	micros0ft-support.example	High - lookalike sender; SPF/DMARC failure
Domain	cdn.secure-login.example	Medium - related post-click resource
IP	203.0.113.77	High - originating mail IP in synthetic evidence
IP	198.51.100.66	High - resolved phishing site IP
IP	198.51.100.91	High - post-click identity sign-in source

7. Attachment Integrity Check

File: Password_Expiration_Instructions.txt

Size: 85 bytes

Detected type: ASCII text

Supplied disposition: Benign decoy / lab artifact

SHA-256: 476a207df465a5c333ec497f9a7a906d2a9d956ccecc8de9074b5a4c85efcae2

The independently calculated hash matched the SHA-256 stored in the supplied attachment metadata. This verifies file integrity within the lab dataset and supports the conclusion that the attachment was not the demonstrated compromise mechanism.

8. Analyst Assessment

The strongest explanation supported by the evidence is credential phishing. The victim received a spoofed Microsoft-themed message, the endpoint resolved and visited the phishing infrastructure, and shortly afterward the same account produced abnormal authentication activity from Amsterdam. The suspicious source first generated an invalid-password failure and then successful password-only sign-ins. The timing and cross-source correlation make benign coincidence unlikely within the synthetic scenario.

Verdict: TRUE POSITIVE **Severity:** HIGH **Confidence:** High

9. Escalation and Recommended Containment

- Escalate immediately to SOC L2 / Incident Response as a confirmed phishing-related account compromise.
- Temporarily disable or restrict the affected account according to organizational procedure.
- Revoke active sessions and authentication tokens.
- Force a password reset and review/re-register MFA as appropriate.
- Block identified phishing domains and infrastructure using available email, DNS, proxy, and security controls.
- Search message trace and endpoint/network telemetry for other recipients or users who interacted with the campaign.

- Review j.smith activity after the suspicious authentication for mailbox changes, persistence, privilege changes, data access, or lateral movement.

Portfolio note: these are analyst recommendations. This case study does not claim the containment actions were actually executed.

10. MITRE ATT&CK; Mapping

Technique	Mapping rationale
T1566 - Phishing	Deceptive Microsoft-themed email directed recipients to phishing infrastructure.
T1204.001 - User Execution: Malicious Link	DNS and proxy evidence show the victim workstation accessing the phishing URL.
T1078 - Valid Accounts	The victim account subsequently authenticated successfully from the suspicious external source.

11. Commands and Analysis Methods Demonstrated

- grep for rapid email-header inspection and authentication-result review.
- Python csv.DictReader for message-trace, proxy, DNS, Windows event, and identity-sign-in analysis.
- Filtering by sender, recipient, user, source IP, host, Event ID, domain, and time window.
- Chronological correlation across multiple telemetry sources.
- Python hashlib SHA-256 calculation for attachment integrity verification.
- Schema/column inspection before querying unfamiliar CSV evidence.

Representative email-header command:

```
grep -Ei "^(From:|Reply-To:|To:|Subject:|Date:|Message-ID:|Authentication-Results:|X-Originating-IP:)"
evidence/suspicious_email.eml
```

Representative authentication inspection:

```
grep -A3 -i "Authentication-Results:" evidence/suspicious_email.eml
```

12. Skills Demonstrated

L1 SOC skills	L2-adjacent skills
Alert triage and validation	Cross-source timeline reconstruction
Email/phishing analysis	Identity compromise correlation
IOC identification	Campaign scoping across recipients
Log filtering and event review	Post-compromise investigation planning
Severity and disposition decisions	MITRE ATT&CK mapping
Escalation documentation	Containment recommendation development

13. Portfolio Disclosure

This case study uses synthetic/dummy lab data for cybersecurity training and portfolio demonstration. IP addresses and domains in the evidence are documentation/lab ranges or synthetic indicators. The report demonstrates investigation methodology and analyst reasoning; it does not represent an incident handled for a real organization.